

Controls and compliance checklist

Case study: Controls and compliance assessment for Botium Toys, based on the risk assessment above, evaluating existing security controls and adherence to PCI DSS, GDPR, and SOC 2 requirements.

Controls assessment checklist

Does Botium Toys currently have this control in place?

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Does Botium Toys currently adhere to this compliance best practice?

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☒	☐	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organization Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☒	☐	Data is available to individuals authorized to access it.

Recommendations

Given the risk score of 8/10, three gaps carry the most exposure and should be prioritized first: encryption of stored and transmitted cardholder data (currently absent, and a direct PCI DSS failure), implementation of least privilege and separation of duties (currently all employees can access cardholder data and customer PII/SPII), and a documented disaster recovery plan with regular backups (currently neither exists, leaving the company with no recovery path after an incident). After those, strengthening the password policy to current complexity standards and deploying a centralized password management system would reduce both account-compromise risk and IT ticket volume. An IDS and a defined asset classification/inventory process would round out the highest-priority items, since both are prerequisites for accurately scoping future risk assessments.